Introduction to Cybersecurity

Cryptography II



Jasmin Azemović
CISO | Associate Professor | Microsoft MVP

Summary

- Calculating the "impossible"?
- Random bit generarators
- Hash functions;
- symmetric encryption
  - Stream cypher;
  - Block Cypher;
  - Data Encryption Standard - DES
- Public Key Infrastructure
  - RSA



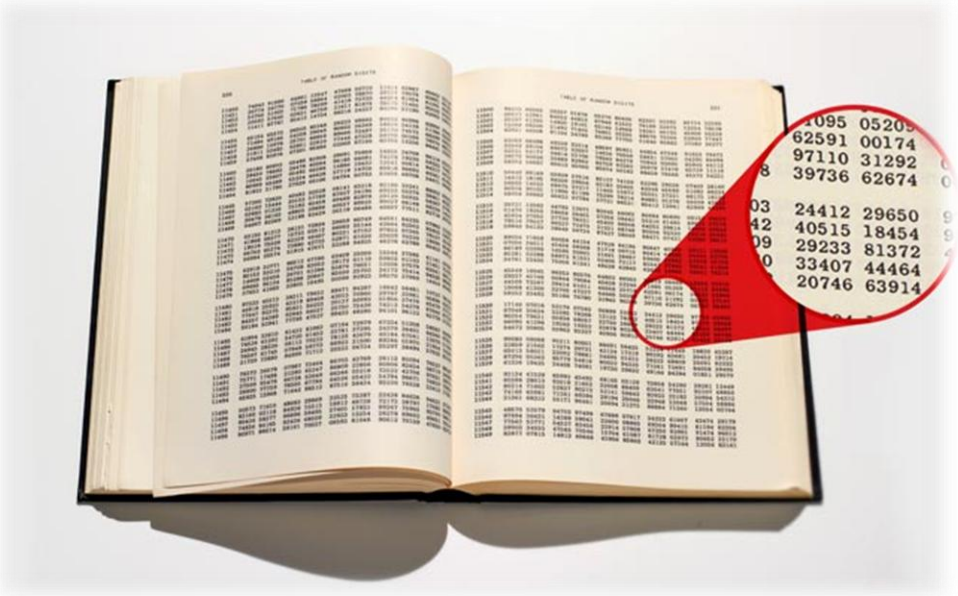
Calculating the "impossible"



- Let's say there are 10 Ghz processors.
- Each costs 10 KM
- In one interval we can test 100 keys
- For the 10 million we can build a machine to test 10^{18} keys per second.
- Such a hypothetical machine could break the 80-bit key for 7 days.
- However, for a 128 bit key would be 10^{12} years
  - Approximately 100 times more than the age of the universe

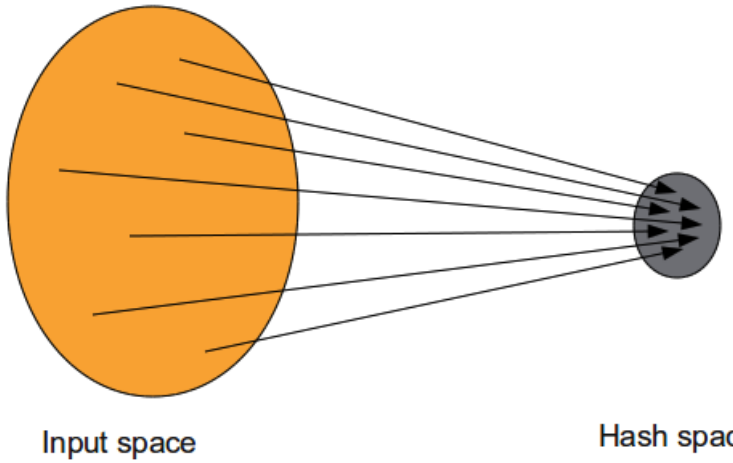
Random bit generators

- Random generators are important, present and essential in all modern cryptographic algorithms.
- The goal is to guess and finding seed value which are non-trivial and difficult to find.
- Examples:
  - Special hardware
  - User activity (keyboard and mouse);
  - Active hardware (CPU, temperature, disk)
  - The content and time flow of network packets
  - The fraction of time



Hash functions

- Effective examples of the practice of fixed length input random function.
- In cryptography used secure hash functions has the following characteristics:
  - One-way: for a given value of y is computationally impossible to find x where h (x) = y
  - Resistance to change. Changing just one bit at the entrance leads to a rapid change in output
- Known examples of hash functions are:
  - MD5 and SHA-a
- 2004 years was found collisions in MD5 function
  - http://www.ietf.org/rfc/rfc1321.txt



Symmetric key cryptography

- Stream cipher - one-time pad
  - The key is a relatively "short"
  - The key is stretched through keystream
  - Keystream used on the principle of one-time pad
- Block cipher - based on a codebook-in
  - Block cipher key determines codebook
  - Each key comes with a different ledger codes
  - Entries "confusion" and "diffusion"

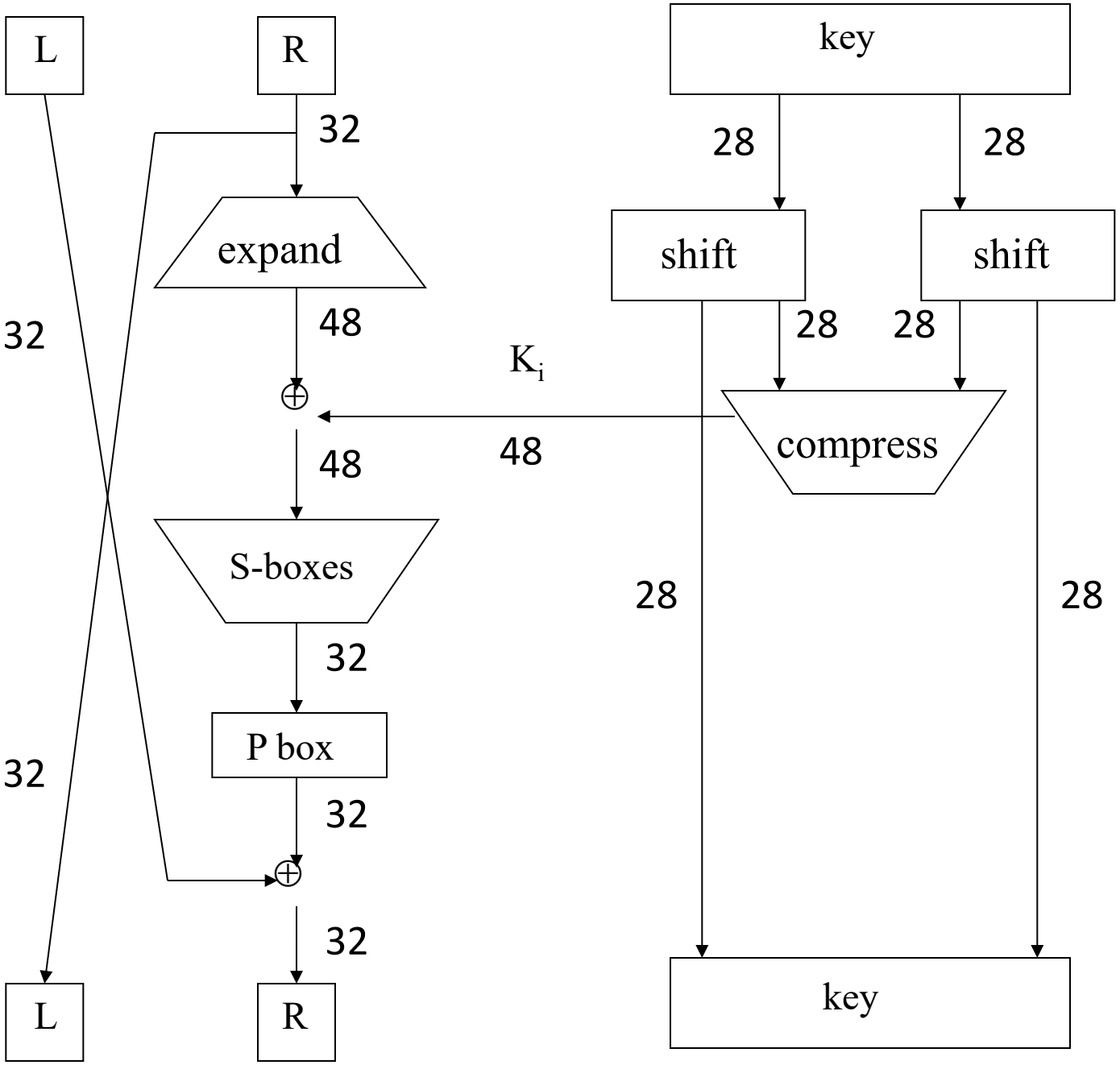
Data Encryption Standard - DES



- DES has developed 70‘s
  - 1977 became the standard
- DES U.S. government was standard
- There was a lot of controversy about the development of this algorithm
  - NSA was involved (Secret)
  - The design was kept secret
  - The key length is reduced from 128 to 56 bits
  - Profusely used by banks and a large number of applications in the past 25 years

DES Numerology

- DES is a Feistel cipher with…
  - 64 bit block length
  - 56 bit key length
  - 16 rounds
  - 48 bits of key used each round (subkey)
- Each round is simple (for a block cipher)
- Security depends heavily on “S-boxes”
  - Each S-boxes maps 6 bits to 4 bits



One Round of DES

DES Expansion Permutation

- Input 32 bits

```
 0  1  2  3  4  5  6  7  8  9 10 11 12 13 14 15
16 17 18 19 20 21 22 23 24 25 26 27 28 29 30 31
```

- Output 48 bits

```
31  0  1  2  3  4  3  4  5  6  7  8
 7  8  9 10 11 12 11 12 13 14 15 16
15 16 17 18 19 20 19 20 21 22 23 24
23 24 25 26 27 28 27 28 29 30 31  0
```

DES S-box

- 8 “substitution boxes” or S-boxes
- Each S-box maps 6 bits to 4 bits
- S-box number 1

input bits (0,5)
↓ input bits (1,2,3,4)

	0000	0001	0010	0011	0100	0101	0110	0111	1000	1001	1010	1011	1100	1101	1110	1111
00	1110	0100	1101	0001	0010	1111	1011	1000	0011	1010	0110	1100	0101	1001	0000	0111
01	0000	1111	0111	0100	1110	0010	1101	0001	1010	0110	1100	1011	1001	0101	0011	1000
10	0100	0001	1110	1000	1101	0110	0010	1011	1111	1100	1001	0111	0011	1010	0101	0000
11	1111	1100	1000	0010	0100	1001	0001	0111	0101	1011	0011	1110	1010	0000	0110	1101

DES P-box

- Input 32 bits

```
 0  1  2  3  4  5  6  7  8  9 10 11 12 13 14 15
16 17 18 19 20 21 22 23 24 25 26 27 28 29 30 31
```

- Output 32 bits

```
15  6 19 20 28 11 27 16  0 14 22 25  4 17 30  9
 1  7 23 13 31 26  2  8 18 12 29  5 21 10  3 24
```

Triple DES

- Today, 56 bit DES key is too small
  - Exhaustive key search is feasible
- But DES is everywhere, so what to do?
  - Not anymore !
- **Triple DES** or **3DES** (112 bit key)
  - $C = E(D(E(P,K_1),K_2),K_1)$
  - $P = D(E(D(C,K_1),K_2),K_1)$
- Why Encrypt-Decrypt-Encrypt with 2 keys?
  - Backward compatible: $E(D(E(P,K),K),K) = E(P,K)$
  - And 112 bits is enough

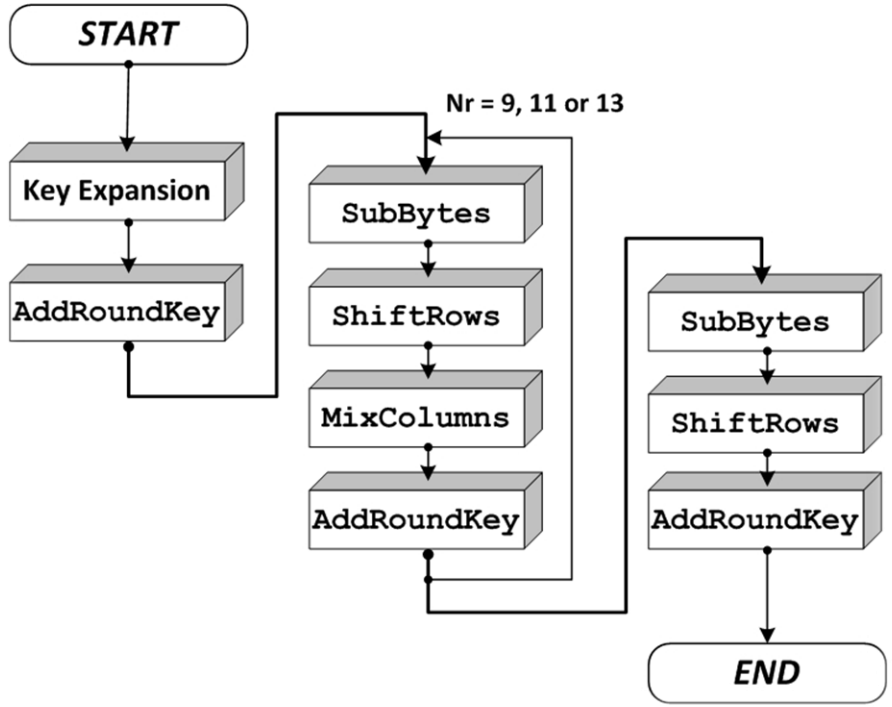
Advanced Encryption Standard

- Replacement for DES
- AES competition (late 90's)
  - NSA openly involved
  - Transparent process
  - Many strong algorithms proposed
  - Rijndael Algorithm ultimately selected (pronounced like "Rain Doll" or "Rhine Doll")
- Iterated block cipher (like DES)
- Not a Feistel cipher (unlike DES)



AES Overview

- **Block size:** 128 bits (others in Rijndael)
- **Key length:** 128, 192 or 256 bits (independent of block size)
- 10 to 14 rounds (depends on key length)
- Each round uses 4 functions (3 “layers”)
  - ByteSub (nonlinear layer)
  - ShiftRow (linear mixing layer)
  - MixColumn (nonlinear layer)
  - AddRoundKey (key addition layer)



A Few Other Block Ciphers

- IDEA
- Blowfish
- RC6
- TEA

Public Key Cryptography

- Two keys
  - Sender uses recipient's **public key** to encrypt
  - Recipient uses **private key** to decrypt
- Based on "trap door one way function"
  - "One way" means easy to compute in one direction, but hard to compute in other direction
  - Example: Given p and q, product $N=pq$ is easy to compute, but given N, it is hard to find p and q
  - "Trap door" used to create key pairs

Public Key Cryptography

- Encryption
  - Suppose we **encrypt** M with Bob's public key
  - Bob's private key can **decrypt** to recover M
- Digital Signature
  - **Sign** by "encrypting" with your private key
  - Anyone can **verify** signature by "decrypting" with public key
  - But only you could have signed
  - Like a handwritten signature (only more so…)

RSA

- RSA algorithm is best known public key cryptography.
- It was named after the initial letters of the surname of its inventors Rivest, Shamir, Adleman
- RSA Security is based on a difficult factoring large numbers.
- Public and private key functions are a pair of large, 100-200 (digits), prime numbers.

33478071698956898786044169848212690817704794983713768568912431388982883793878002287614711652531743087737814467999489

* *3674604366679959042824463379962795263227915816434308764267603228381573966651127923337341714339681027009279873630891 7*

= *1230186684530117755130494958384962720772853569595334792197322452151726400507263657518745202199786469389956474942774063845925192557326303453731548268507917026122142913461670429214311602221240479274737794080665351419597459856902143413*

RSA SECURITY™

Simple RSA Example

- Example of RSA
  - Select “large” primes $p = 11, q = 3$
  - Then $N = pq = 33$ and $(p-1)(q-1) = 20$
  - Choose $e = 3$ (relatively prime to 20)
  - Find d such that $ed = 1 \bmod 20$
    - We find that $d = 7$ works
- **Public key:** $(N, e) = (33, 3)$
- **Private key:** $d = 7$

Simple RSA Example

- **Public key:** $(N, e) = (33, 3)$
- **Private key:** $d = 7$
- Suppose message $M = 8$
- Ciphertext C is computed as

  $C = M^e \bmod N = 8^3 = 512 = 17 \bmod 33$

- Decrypt C to recover the message M by

  $M = C^d \bmod N = 17^7 = 410{,}338{,}673 = 12{,}434{,}505 * 33 + 8 = 8 \bmod 33$

One more example

Formal definition

1. Choose two primes p and q with $p \neq q$
2. Calculate their product: $N = p * q$
3. Calculate the value of Euler's totient function of N

$$\varphi(N) = \varphi(p * q) = (p-1)(q-1)$$

4. Choose a number e between 1 and $N-1$ which is coprime to $\varphi(N)$
5. Find another number d where

$$d * e \equiv 1 \; mod \; \varphi(N)$$

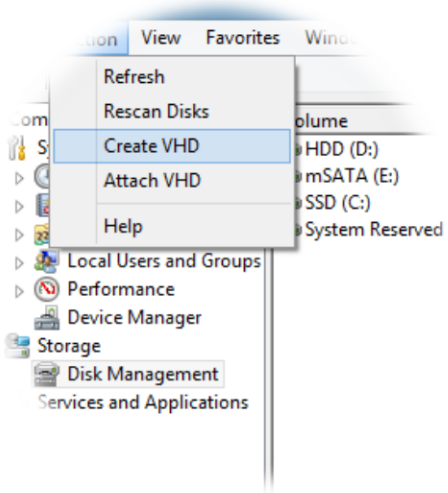
Example:

1. Suppose we select $p = 13$ and $q = 7$
2. Thus: $N = 13 * 7 = 91$
3. $\varphi(91) = \varphi(13 * 7) = (13-1)(7-1) = 72$
4. Suppose we choose $e = 5$, because:
   $gcd(5, 72) = 1$
5. We will select $d = 29$ as thus:
   $d * e = 145 = 2 * 72 + 1 \equiv 1 \; mod \; 72$

(e, N) is *public RSA key*
(d, N) is *private RSA key.*

Usage





- File encryption
- Disk encryption
- Email encryption
- HTTPS
- Diffie-Hellman key exchange protocol
- VPN
- Chat encryption (end2end)
- Anonymous surfing
- …







